Management der Informationssicherheit

Teil1: Begriffe, Schutzziele, Standards und Normen, Aufbau eines Informationssicherheits-Managmentsystems (ISMS) nach BSI IT-Grundschutz, Phase 1-3 des Sicherheitsprozesses nach BSI IT-Grundschutzmethodik

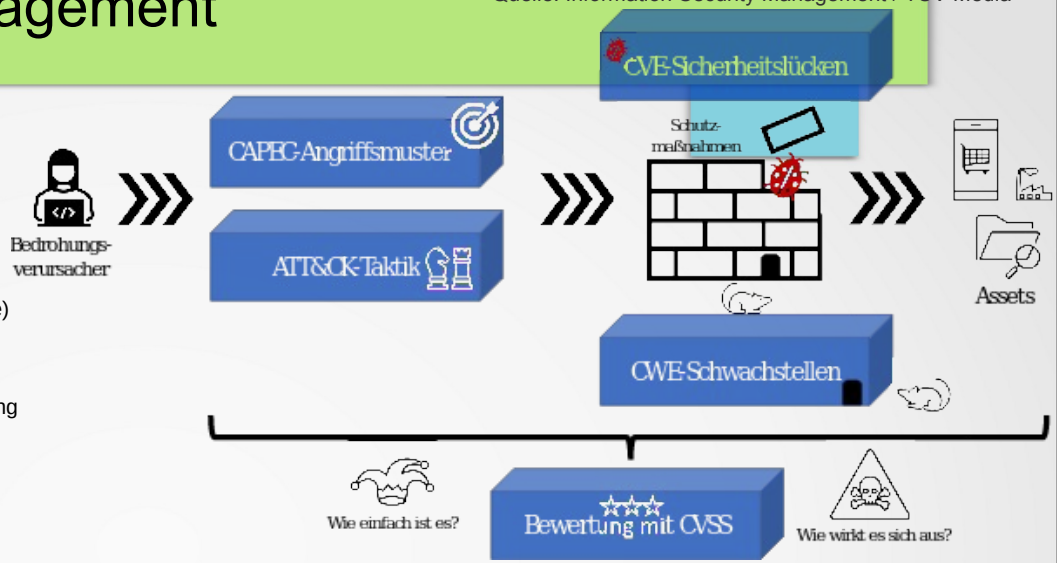
Informationssicherheitsmanagement

- **Begriff „Informationssicherheit“**:
  - **„data is the new oil“**: Informationen sind (in unserer zunehmend vernetzten Welt) Werte von entscheidender Wichtigkeit für Unternehmen (wie Privatpersonen)
    - Das jährliche erzeugte Datenvolumen betrug 2016 etwa 16 ZB – 2025 wird diese Menge lt IDC-Studie „Data Age 2025“ auf etwa 160 ZB anwachsen
  - **Information kann in unterschiedlicher Form vorliegen** (analog/digital – bspw Papier, HDD, Film) **und übertragen werden** (bspw Post, Funk, elektronisch)
  - Informationssicherheit hat das Ziel **Informationen (aller Art) vor der zunehmenden Anzahl an Bedrohungen zu schützen** und umfasst somit ua IT-Sicherheit, Datensicherung (Backup) oder Datensicherheit (eine wesentliche Voraussetzung für effektiven Datenschutz)

Informationssicherheitsmanagement

Quelle: Information Security Management / TÜV Media

- **Bedrohungen für Informationssicherheit (Auswahl)**:
  - Feuer, Wasser, Naturkatastrophen
  - Sabotage
  - Spionage / Abhören
  - Schadprogramme (Viren, Trojaner, Würmer, Ransomware)
  - Fehlbedienung durch Personal
  - Ressourcenmangel, Fehlplanung oder fehlende Anpassung
  - Offenlegung schützenswerter Informationen
  - Missbrauch personenbezogener Daten
  - Integritätsverlust schützenswerter Informationen
  - Verstoß gegen Gesetze oder Regelungen
  - Identitätsdiebstahl (zB durch Phishing)
  - Verhinderung von Diensten ([Distributed] Denial of Service)
  - Ausfall oder Störung der Stromversorgung oder von Kommunikationsnetzen
  - Diebstahl, Verlust oder Zerstörung von Geräten, Datenträgern oder Dokumenten
  - Unberechtigte oder fehlerhafte Nutzung oder Administration von Geräten und Systemen
  - Unbefugtes Eindringen in IT-Systeme (bspw Advanced Persistent Threats[1)] – Bsp russisches Hackerkollektiv Sofacy, das im US-Wahlkampf 2016 Datenspionage betrieben hat) oder Räumlichkeiten
  - Social Engineering (Angreifer gibt sich zB während eines Telefonanrufs als Techniker aus und fragt einen Mitarbeiter nach dessen Benutzername/Passwort um wichtige Wartungsarbeiten abzuschließen können)
  - Software-Schwachstellen oder -Fehler (bspw Drive-by-Exploits und Exploit-Kits[2)], die Schwachstellen in (veralteten) Browser, Browser-Plugins oder Betriebssystemen ausnutzen)



CAPEC (Common Attack Pattern Enumerations and Classifications) listet und klassifiziert Angriffsmuster. Att&ck klassifiziert strategisch taktische Vorgehensweisen von Angreifern. Die CVE (Common Vulnerability Enumeration) veröffentlicht, bewertet und katalogisiert gemeldete Sicherheitslücken (CWE steht für Common Weakness Enumeration). Das Common Vulnerability Scoring System (CVSS) bewertet Sicherheitslücken hinsichtlich Ausnutzbarkeit und Schadenspotenzial – zusätzlich gibt es mit dem EPSS (Exploit Prediction Scoring System) auch eine Einschätzung wie wahrscheinlich es ist , dass eine bestimmte Schwachstelle (CVE) in den nächsten 30 Tagen ausgenutzt wird.

[1)] APT-Attacken zielen häufig darauf ab, Informationen zu stehlen und weniger das Netzwerk der angegriffenen Organisation zu schädigen. Das Ziel vieler APT-Angriffe (Advanced Persistent Threat) ist es, dauerhaften Zugang zum Zielnetzwerk zu erlangen und aufrechtzuerhalten und nicht, so schnell wie möglich hinein- und hinauszukommen.

[2)] Besonders problematisch sind sog. Zero-Day-Exploits. Diese werden eingesetzt, bevor es einen Patch als Gegenmaßnahme gibt. Entwickler haben dadurch keine Zeit (zero day), die Software so zu verbessern, sodass der Exploit unwirksam wird, um Nutzer zu schützen. Entdeckt eine Person eine Sicherheitslücke und meldet sie nicht dem Software-Hersteller, sondern entwickelt einen Exploit, um diese auszunutzen, wird die Schwachstelle der Software oft erst lange nach dem ersten Angriff bekannt.

Informationssicherheitsmanagement

- **(weitere) Gründe für Informationssicherheitsmanagement:**
  - **Gesetzliche Notwendigkeit** (bspw EU-DSGVO, NIS-RL/NISG[1)], DORA[3)], Signaturgesetz SigG, Telekommunikationsgesetz TKG, Urheberrechtsgesetz UrhG, EGovG[2)], …)
  - (zertifizierte) Informationssicherheit eines Unternehmens ist wichtig für Partnerunternehmen und Kunden => **Wettbewerbsvorteil**
    - Dienstleister möchten mithilfe des Zertifikats einen vertrauenswürdigen Nachweis führen, dass sie entsprechende Maßnahmen (zB gemäß BSI IT-Grundschutz) realisiert haben
    - Kooperierende Unternehmen möchten sich darüber informieren, welchen Grad von Informationssicherheit ihre Geschäftspartner zusichern können
    - Von Institutionen, die neu an ein Netz angeschlossen werden, wird der Nachweis darüber verlangt, dass sie eine ausreichende Informationssicherheit besitzen, damit durch den Anschluss ans Netz keine untragbaren Risiken entstehen
    - Institutionen möchten dem Kunden bzw. Bürger gegenüber ihre Bemühungen um eine ausreichende Informationssicherheit deutlich machen
  - **Risiken werden besser erkannt** und (besonders hohe) **Schäden vermieden** => wichtige Grundlage für zielgerichtete Investitionen
  - Organisatorische Umstellung/Einführung führt zu erhöhtem Sicherheitsbewusstsein (**Awareness**) bei allen Mitarbeitern und wirkt somit präventiv

[1)] EU-Richtlinie 2016/1148 über Maßnahmen zur Gewährleistung eines hohen gemeinsamen Sicherheitsniveaus von Netz- und Informationssystemen – in Österreich umgesetzt durch das Netz- und Informationssicherheitsgesetz (NISG) … Die Folgerichtlinie NIS2 2022/2555, die Unternehmen kritischer Sektoren (Wasser, Gesundheit, Digitale Infrastruktur & Services, Finanz, Verwaltung, Post, Lebensmittel, ...) betrifft, wurde im Dezember 2022 publiziert und sollte bis 17. Oktober 2024 in nationales Recht umgesetzt werden (Österreich säumig: Inkrafttreten 1.10.2026 => NISG 2026)
[2)] Bundesgesetz über Regelungen zur Erleichterung des elektronischen Verkehrs mit öffentlichen Stellen
[3)] Der Digital Operational Resilience Act (EU-Verordnung 2022/2554) enthält Vorschriften zur Informationssicherheit im Finanzsektor und gilt ab 2025

Informationssicherheitsmanagement

- **Schutzziele (nach ISO/IEC 27001)**:
  - **Vertraulichkeit (confidentiality)**:
    - bezeichnet die Eigenschaft, dass eine Information für unautorisierte Personen, Entitäten oder Prozesse nicht zugänglich ist und von diesen auch nicht offengelegt werden kann
    - ist bspw verletzt, wenn ein Angreifer eine Kommunikation abhören kann
  - **Integrität (integrity)**:
    - bezeichnet jene Eigenschaft, die Werte im Hinblick auf ihre Richtigkeit und Vollständigkeit schützt
    - eine Integritätsprüfung (zB mittels Hashfunktion) einer digitalen Information oder Nachricht erkennt jede Veränderung an der Nachricht
    - verhindert Man-in-the-Middle-Angriffe
  - **Verfügbarkeit (availability)**:
    - bezeichnet die Eigenschaft einer Information oder eines Wertes, für einen berechtigten Nutzer verfügbar und nutzbar zu sein, sobald der Nutzer dies verlangt
    - wird zB durch Elementarschäden oder Katastrophen bedroht
    - prominenteste Angriffe auf die Verfügbarkeit von Diensten oder Ressourcen sind Denial of Service (DoS) oder Distributed Denial of Service (DDoS) Attacken

Informationssicherheitsmanagement

- **Schutzziele (nach ISO/IEC 27001)**:
  - **Authentizität (authenticity)**:
    - bezeichnet die Eigenschaft einer Entität, das zu sein, was sie vorgibt zu sein (also die „**Echtheit**“ bspw einer Person)
    - zur Prüfung der Authentizität muss sich eine Person zunächst **authentisieren** (also durch Angabe bestimmter Daten wie bspw Benutzername/Passwort, Reisepass, Fingerabdruck seine Identität behaupten) um dann durch eine Kontrollinstanz **authentifiziert** zu werden (dabei wird die Identitätsprüfung durchgeführt)
      - Nach erfolgreicher Authentifizierung kommt es manchmal auch noch zur Einräumung/Zuweisung bestimmter Rollen/Rechte (**Autorisierung**)
  - **Zugriffssteuerung**:
    - Stellt sicher, dass der **Zugang** zu Informationen bzw Ressourcen/Assets **nur autorisiert** erfolgen darf und setzt somit ein **Berechtigungskonzept** um

Informationssicherheitsmanagement

- **Schutzziele (nach ISO/IEC 27001)**:
  - **Verlässlichkeit (reliability)**:
    - Bezeichnet die Eigenschaft, ein konsistentes und spezifikationsgemäßes Verhalten zu zeigen und konsistente Ergebnisse zu liefern
    - Bspw würde eine Verschlüsselungssoftware für E-Mails, die jede dritte Nachricht unverschlüsselt überträgt, die Sicherheitsanforderung nach Verlässlichkeit nicht erfüllen
  - **Nichtabstreitbarkeit / Verbindlichkeit (non-repudiation)**:
    - bezeichnet den Vorgang, mit dem der **Eintritt eines Ereignisses oder einer Aktion sowie die verursachende Entität zweifelsfrei belegt** werden können
    - Bspw soll ein Absender das Absenden einer bestimmten Nachricht nachträglich nicht bestreiten können bzw ein Empfänger den Erhalt einer gesendeten Nachricht nachträglich nicht bestreiten können
  - **Zurechenbarkeit (accountability)**:
    - Realisiert die **Verantwortlichkeit einer Entität für ihre Aktionen und Entscheidungen**, dh sicherheitsrelevante Aktionen müssen demjenigen, der sie durchgeführt hat, zurechenbar sein

Informationssicherheitsmanagement

- **Relevante Standards und Normen zum Management der Informationssicherheit**:
  - **ISO/IEC 27000 Standardfamilie**:
    - Bekanntester internationaler Standard im Bereich Informationssicherheit => **zertifizierbar**!
    - spezifiziert die Anforderungen für Einrichtung, Umsetzung, Aufrechterhaltung und fortlaufende Verbesserung eines dokumentierten Informationssicherheits-Managementsystems (ISMS) unter Berücksichtigung des Kontexts einer Organisation
  - **Payment Card Industry Data Security Standard (PCI DSS)**: stellt ein (ua von Mastercard, VISA und JCB entwickeltes) verbindliches Rahmenwerk für die Entwicklung eines robusten Sicherheitsprozesses für Kreditkartendaten/-transaktionen bereit und umfasst sowohl die Sicherheitsprävention als auch die Erkennung und angemessene Reaktion auf Sicherheitsvorfälle
  - **BSI IT-Grundschutz** (Bundesamt für Sicherheit in der Informationstechnik, Deutschland), **Österreichisches Informationssicherheitshandbuch** (sicherheitshandbuch.gv.at), Melde- und Anlaufstelle Informationssicherung (**MELANI**, Schweiz), Cyberworld Awareness and Security Enhancement Services (**CASES**, Luxemburg)
  - **NIST SP 800-xx**
  - **ITIL** (IT Infrastructure Library)**, CobiT** (Control Objectives for Information and related Technology), **ISO 20000** (Norm zum IT Service Management)
  - **ISF** (Information Security Forum) “The **Standard of Good Practice for Information Security**"**,** Open Web Application Security Project (**OWASP**), **ÖNORM 7700** (Sichere Webapplikationen)

Informationssicherheitsmanagement

- **BSI IT-Grundschutz**:
  - Vom BSI[1)] entwickelte **Vorgehensweise zum Identifizieren und Umsetzen von Sicherheitsmaßnahmen der Informationstechnik** (IT) einer Institution (zB Behörde oder Unternehmen)
  - Ziel des Grundschutzes ist dabei das **Erreichen eines mittleren, angemessenen und ausreichenden Schutzniveaus für IT-Systeme**
  - Die Methodik wird dabei in **4 BSI-Standards** definiert
  - Konkretisiert Maßnahmen durch ein (laufend aktualisiertes) umfangreiches **IT-Grundschutz-Kompendium**
  - **Idee**: konkrete Maßnahmen zur Informationssicherheit schrittweise (in Form von **Bausteine**n und **unterschiedliche**n **Absicherungsniveaus**), schnell und wirtschaftlich machbar sowie effektiv umsetzen
  - abgestimmt auf ISO 27001 => Zertifizierung nach ISO 27001 auf Basis IT-Grundschutz möglich

[1)] Das Bundesamt für Sicherheit in der Informationstechnik ist hervorgegangen aus einer geheimen Dienststelle des Bundesnachrichtendienstes (BND), der "Zentralstelle für das Chiffrierwesen", und residiert in Bonn. Ca 1800 Beschäftigte (Stand 2024) befassen sich dort (auf Grundlage des BSI-Errichtungsgesetzes 1990) mit der Untersuchung von Sicherheitsrisiken im informationstechnischen Bereich von Bundesbehörden, die Entwicklung, Prüfung und Anwendung kryptographischer Verfahren für den Informationsaustausch, die Prüfung und Zertifizierung von informationstechnischen Systemen, Unterstützung und Beratung von Bundesbehörden, Strafverfolgungsbehörden, Verfassungsschutzbehörden (diese nur mit IT-Bezug) und Unternehmen und Organisationen (Wirtschaftsspionage).

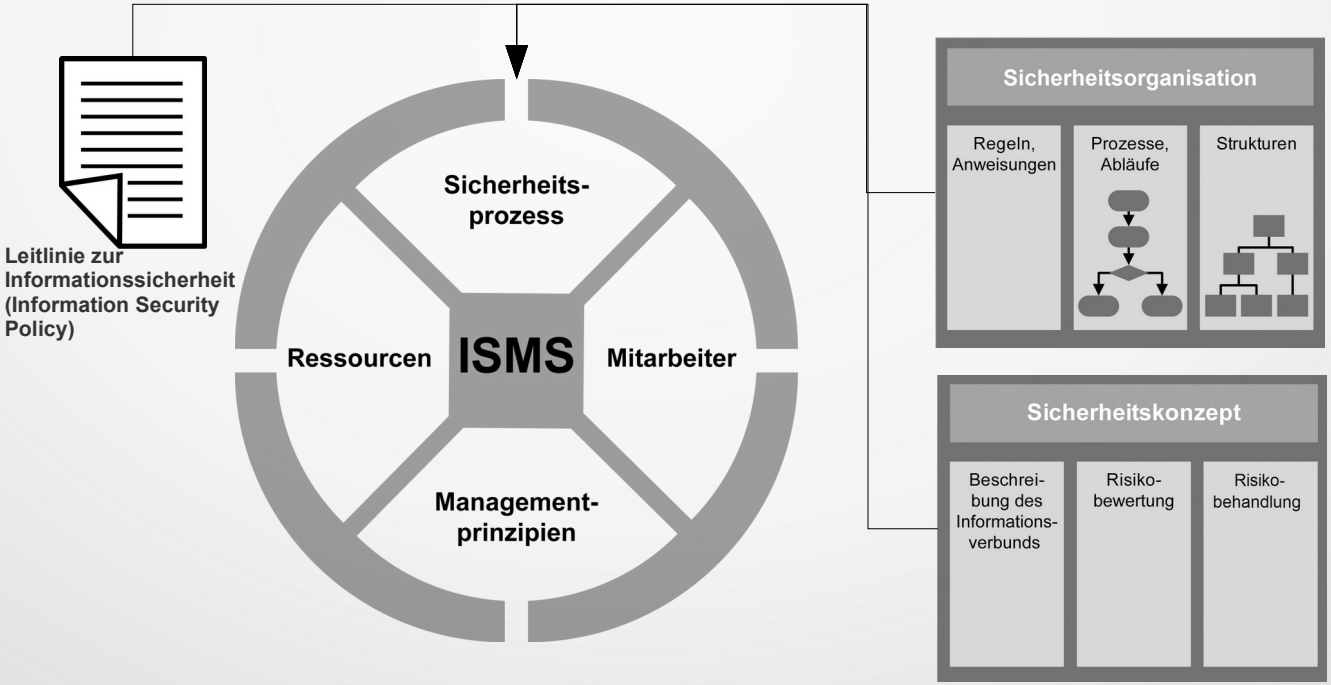
Informationssicherheitsmanagement

- **BSI IT-Grundschutz – 4 Standards[1)]**:
  - 200-1: Managementsysteme für Informationssicherheit
    - Anforderungen an das System (ISO 27.000)
  - 200-2: Vorgehensweise nach IT-Grundschutz
    - Konkrete Vorgehensweise zur Umsetzung von 200-1
  - 200-3: Risikoanalyse auf der Basis von IT-Grundschutz
    - Risikoanalysen für Besonderheiten (über den Grundschutz hinausgehende Komponenten bzw Komponenten mit [besonders] erhöhtem Schutzbedarf) erstellen
  - 200-4: Business Continuity Management (BCM, vormals: Notfallmanagement)
    - Vorbereitung auf und Bewältigung von Notfällen (vgl. ISO 20.000, ITIL)
- **BSI IT-Grundschutz-Kompendium[1)]**:
  - Umfasst für übliche Komponenten eines IT-Systems (sog Bausteine), Bedrohungen, Sicherheitsanforderungen (auf 3 Niveaus: Basis, Standard und erhöhter Bedarf) und konkrete Maßnahmen zur Gestaltung bzw Umsetzung

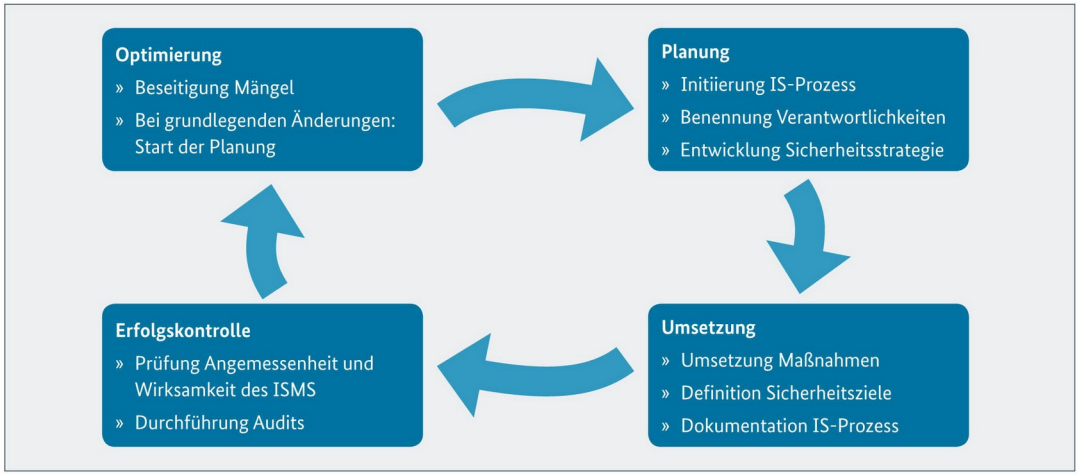
[1)] Im Oktober 2017 wurden die knapp 10 Jahre alten BSI-Standards 100-1, 100-2 und 100-3 sowie die IT-Grundschutzkataloge durch die neuen Standards 200-1, 200-2 und 200-3 sowie das IT-Grundschutz-Kompendium ersetzt. Die Aktualisierung des Standards 100-4 wurde (erst verspätet) Mitte 2023 abgeschlossen.

Informationssicherheitsmanagement

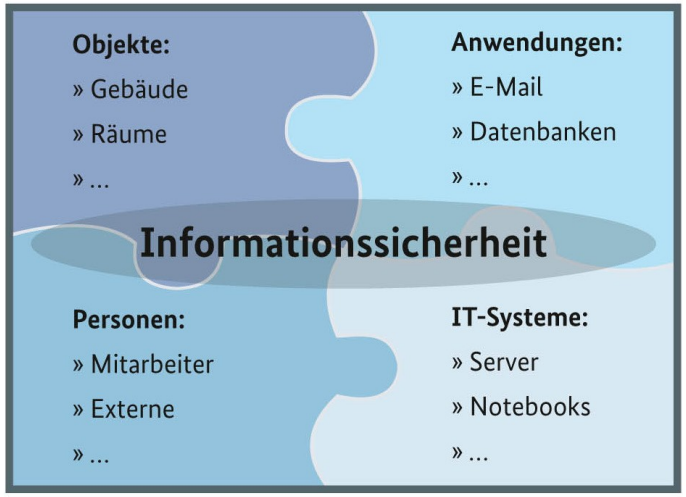
- **BSI IT-Grundschutz – Methodik / Vorgehensweise (nach BSI 200-2):**
  - Management von Informationssicherheit erfordert einen **ganzheitlichen systematischen Ansatz** (und nicht nur punktuelle Maßnahmen wie bspw die Installation von Antivirus-Software oder Firewalls) und umfasst (lt BSI 200-1) folgende Komponenten:

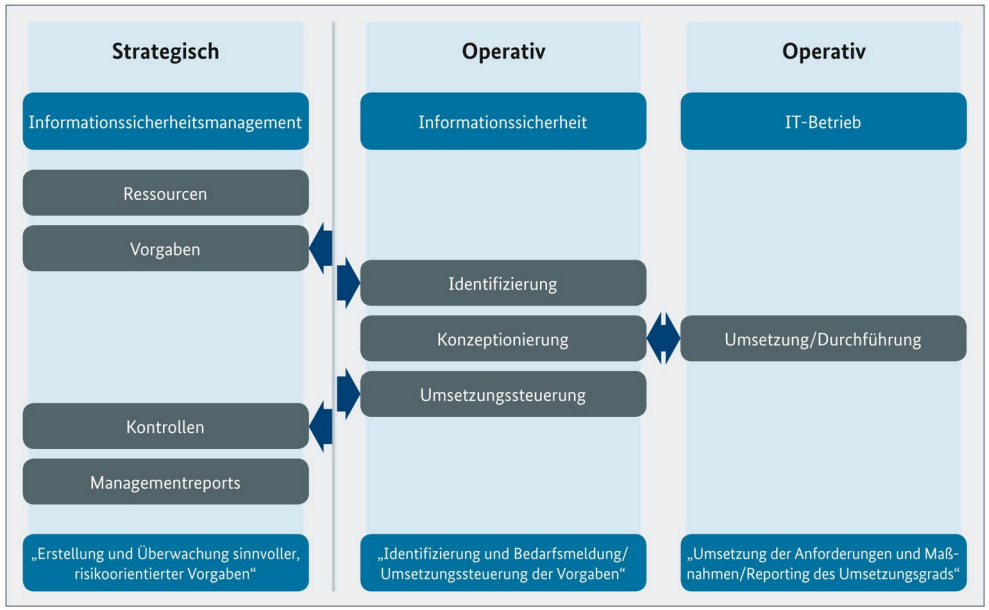


Informationssicherheitsmanagement



Um (ein angemessenes) Informationssicherheit(sniveau) gewährleisten zu können ist ein **kontinuierlicher (IS-)Prozess** (links: PDCA-Zyklus), der **auf mehreren Ebenen** (organisatorisch wie technisch) mit verschiedenen Aufgaben und Verantwortlichkeiten abläuft und den **gesamten Lebenszyklus** (Planung, Beschaffung, Umsetzung, Betrieb, Aussonderung, Notfallvorsorge) **von IT-Systemen umfasst**, notwendig.





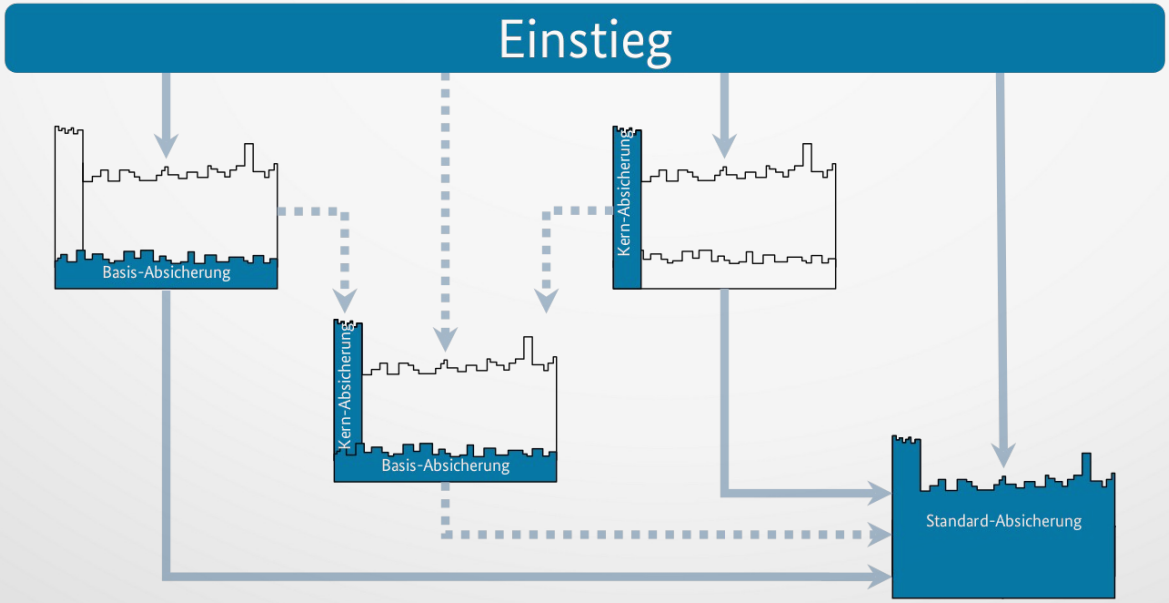
Informationssicherheitsmanagement

- **Bausteine:**
  - Das BSI definiert im IT-Grundschutz-Kompendium standardisierte Sicherheitsanforderungen für typische Geschäftsprozesse, Anwendungen und IT-Systeme in Form sog Bausteine (bspw APP.3.2 „Webserver“, SYS.1.3. „Server unter Unix“, OPS.1.1.4 „Schutz vor Schadprogrammen“)
  - Ein Unternehmen kann aus diesem Baukasten passende Elemente auswählen (Modellierung)
  - Für jeden Baustein wurde dabei bereits eine entsprechende Risikobeurteilung (Gefährdungen, Eintrittswahrscheinlichkeit / Schadensausmaß) durchgeführt (und daraus die Sicherheitsanforderungen [und tlw auch Umsetzungsmaßnahmen] abgeleitet) => schnellere Umsetzung von IS-Maßnahmen
  - Bausteine sind folgendermaßen strukturiert:
    - Beschreibung des Zielobjekts
    - Zielsetzungen (=Sicherheitsgewinn bei Umsetzung)
    - Abgrenzungen / Verweise
    - Spezifische Gefährdungen (abgeleitet von elementaren Gefährdungen[1])
    - Anforderungen zur Erreichung der einzelnen Schutzniveaus (Basis/Standard/erhöht)
    - Kreuzreferenztabelle (=Matrix zur Darstellung der Zusammenhänge zw Anforderungen und elementaren Gefährdungen) => möglicher Ausgangspunkt für vertiefte Risikoanalyse

[1] Aktuell sind 47 elementare Gefährdungen für die IT-Grundschutz-Methodik und hier vor allem für die Arbeit mit dem IT-Grundschutz-Kompendium identifiziert und beschrieben. Diese elementaren Gefährdungen (Feuer, Wasser, Naturkatastrophen, [Identitäts]diebstahl, Ressourcenmangel, Ausfall von Strom/Kommunikationsnetzen, Spionage, Verlust, ...) gelten für verschiedenste Bausteine und können für die Risikoanalyse herangezogen werden. Sie sind kompatibel mit vergleichbaren internationalen Katalogen und Standards.

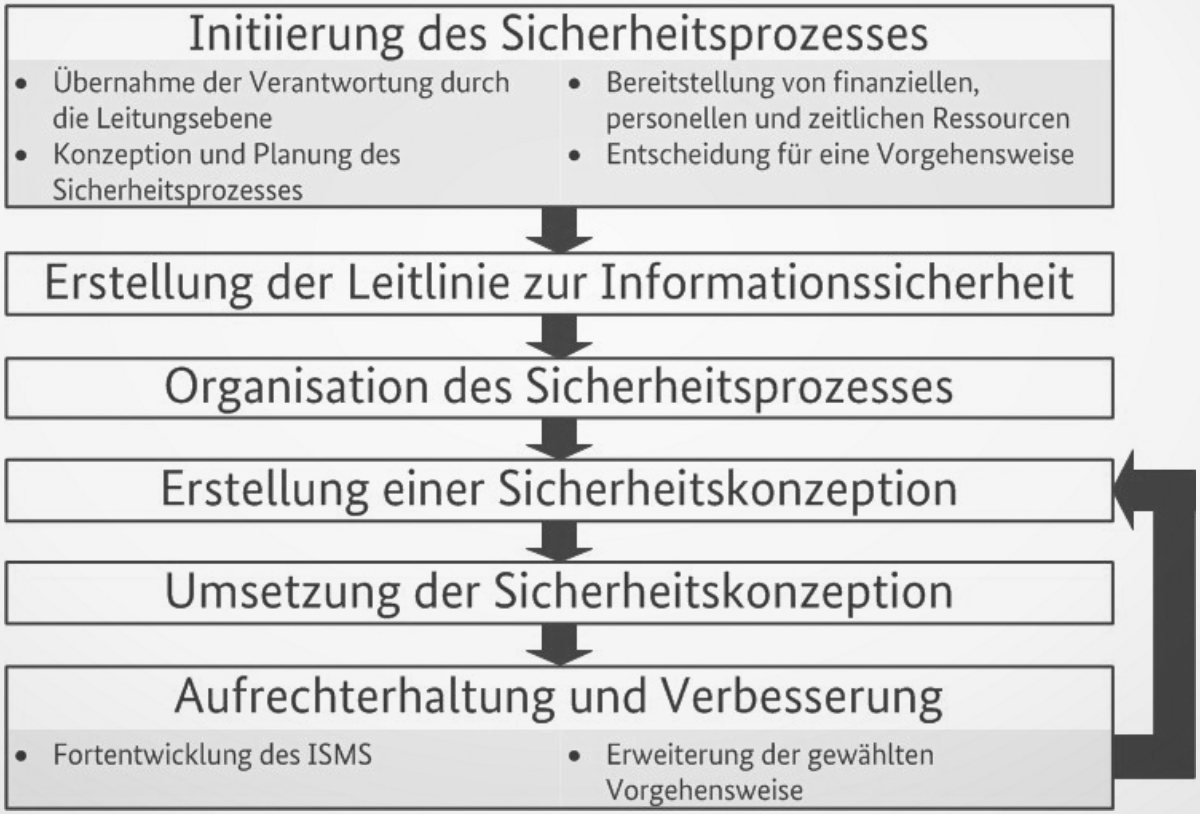
Informationssicherheitsmanagement

- **Sicherheitsniveaus:**
  - Für die einzelnen Bausteine sind die Anforderungen zur Gewährleistung der Sicherheit 3 verschiedenen Niveaus (***Basis***, ***Standard***, ***bei erhöhtem Schutzbedarf***) zugeordnet
  - Ein Unternehmen kann selbst entscheiden welche Art der Absicherung (**Basis-/Standard-/Kernabsicherung**) es anstrebt – es könnte zB zunächst mit einer Basis-Absicherung (elementare Sicherheitsanforderungen) uU kombiniert mit ersten Kern-Absicherungen sog Kronjuwelen (wichtigste Teile des Informationsverbunds) beginnen und erst danach mit einer Standard-Absicherung (Schutzbedarfskategorie „normal“) beginnen



Informationssicherheitsmanagement

- **Informationssicherheitsprozess (nach BSI 200-2)**:



Informationssicherheitsmanagement

- **IS-Prozess – Phase#1 „Initiierung“**:
  - ***Übernahme der Verantwortung durch die Leitungsebene***:
    - Die Leitungsebene informiert sich über mögliche Risiken und Konsequenzen aufgrund fehlender Informationssicherheit
    - Die Leitungsebene **übernimmt die Gesamtverantwortung** für Informationssicherheit
    - Die Leitungsebene initiiert den Informationssicherheitsprozess innerhalb der Institution und **benennt einen Verantwortlichen** für Informationssicherheit (Informationssicherheitsbeauftragter ISB oder Chief Information Security Officer CISO)
    - Die Leitungsebene **stellt entsprechende Ressourcen** für das IS-Management sicher/**bereit**

Informationssicherheitsmanagement

- **IS-Prozess – Phase#1 „Initiierung“:**
  - **Konzeption und Planung**:
    - **Ermittlung von Rahmenbedingungen**: Ermittlung der wichtigsten Geschäftsprozesse / Aufgaben und Analyse welche Sicherheitsanforderungen aufgrund der Geschäftsprozesse, Stakeholder und Partner an die Informationstechnik gestellt werden
    - Formulierung von **allgemeinen Informationssicherheitsziele**n: Verlässlichkeit, guter Ruf, Einhaltung gesetzlicher Vorgaben, Schutz natürlicher Personen, ...
    - **Bestimmung des angemessenen Sicherheitsniveaus** (Schutzbedarfskategorien: „sehr hoch“, „hoch“, „normal“) der Geschäftsprozesse
      - Welche Informationen sind in Bezug auf Vertraulichkeit, Integrität und Verfügbarkeit besonders kritisch für die Institution?
      - Welche kritischen Aufgaben der Institution können ohne Unterstützung durch IT nicht, nur unzureichend oder mit erheblichem Mehraufwand ausgeführt werden?
      - Welche organisatorischen oder gesetzlichen Anforderungen (z. B. Datenschutz) haben besondere Maßnahmen zur Folge?
    - **Ersterfassung (grob) der Prozesse, Anwendungen und IT-Systeme** (zB in Form von Prozesslandkarten, Geschäftsprozessmodellen/-diagrammen, Anwendungslandkarten/Bebauungsplänen, Netzplänen, usw)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#1 „Initiierung“:**
  - **Entscheidung für eine der folgenden Vorgehensweisen (1/3):**
    - **Basis-Absicherung, falls:**
      - Die Umsetzung von Informationssicherheit noch am Anfang steht, d. h. die Informationssicherheit bisher nur einen **niedrigen Reifegrad** erreicht hat
      - Die **Geschäftsprozesse kein deutlich erhöhtes Gefährdungspotenzial** bezüglich der Informationssicherheit aufweisen
      - Der Schutzbedarf elementar ist
      - keine Assets vorhanden sind, deren Diebstahl, Zerstörung oder Kompromittierung einen existenzbedrohenden Schaden für die Institution bedeutet
      - Kleinere Sicherheitsvorfälle toleriert werden können – also solche, die zwar Geld kosten oder anderweitig Schaden verursachen, aber in der Summe nicht existenzbedrohend sind

Informationssicherheitsmanagement

- **IS-Prozess – Phase#1 „Initiierung“:**
  - **Entscheidung für eine der folgenden Vorgehensweisen (2/3):**
    - **Kern-Absicherung, falls:**
      - Die **Menge der Geschäftsprozesse mit deutlich erhöhtem Schutzbedarf** (Schutzbedarfskategorie idR „hoch“ oder „sehr hoch“) **überschaubar ist** bzw. nur einen kleinen Anteil aller Geschäftsprozesse der Institution umfasst
      - Die Institution die Geschäftsprozesse, die ein deutlich erhöhtes Gefährdungspotenzial bezgl der Informationssicherheit aufweisen, zügig identifizieren und eindeutig abgrenzen kann
      - Die Institution **eindeutig benennbare Assets** besitzt, deren Diebstahl, Zerstörung oder Kompromittierung einen **existenzbedrohenden Schaden für die Institution** bedeuten würde (sogenannte **Kronjuwelen**) => Diese sollen vorrangig geschützt werden
      - Kleinere Sicherheitsvorfälle, die Geld kosten oder anderweitig Schaden verursachen, aber keinen existenzbedrohenden Schaden bedeuten, für die Institution akzeptabel sind

Informationssicherheitsmanagement

- **IS-Prozess – Phase#1 „Initiierung“:**
  - **Entscheidung für eine der folgenden Vorgehensweisen (3/3):**
    - **Standard-Absicherung, falls:**
      - Die **Institution bereits mit dem IT-Grundschutz arbeitet**
      - schon Sicherheitskonzepte nach IT-Grundschutz oder ISO 27001 erstellt wurden oder eine **Zertifizierung nach ISO 27001** angestrebt wird
      - Die Umsetzung von Informationssicherheit in der Institution bereits einen ausreichenden Reifegrad erreicht hat, sodass in wesentlichen Bereichen bereits Sicherheitsmaßnahmen vorhanden sind und **keine grundlegende Erst-Absicherung** mehr notwendig ist
      - kein Handlungsbedarf besteht, einzelne Geschäftsprozesse vordringlich abzusichern, die ein deutlich höheres Gefährdungspotenzial bezgl der Informationssicherheit besitzen (=> Kern-Absicherung)
      - Die Institution keine Assets hat, deren Diebstahl, Zerstörung oder Kompromittierung einen unmittelbar existenzbedrohenden Schaden nach sich ziehen könnte und die daher vorrangig abgesichert werden sollten
      - Sicherheitsvorfälle, die wahrnehmbar die Aufgabenerfüllung beeinträchtigen, Geld kosten oder anderweitig erkennbaren Schaden verursachen, für die Institution nicht akzeptabel sind, auch wenn sie noch keinen existenzbedrohenden Schaden verursachen.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#1 „Initiierung“:**
  - **Definition des Geltungsbereichs (für die Sicherheitskonzeption)**
    - Es muss nicht (gleich zu Beginn) der gesamte Informationsverbund[1)] abgesichert werden
    - Bsp: Beschränkung auf eine Organisationseinheit, (kleine) Menge an Geschäftsprozessen (inkl aller dafür notwendiger Organisationseinheiten und technischer Grundlagen)
- **IS-Prozess – Phase#2 „Erstellung einer Leitlinie zur Informationssicherheit“ (Information Security Policy) – Inhalt:**
    - Stellenwert der Informationssicherheit und Bedeutung der wesentlichen Informationen, Geschäftsprozesse und der IT für die Aufgabenerfüllung,
    - Bezug der Informationssicherheitsziele zu den Geschäftszielen oder Aufgaben der Institution,
    - Sicherheitsziele und die Kernelemente der Sicherheitsstrategie für die Geschäftsprozesse und die eingesetzte IT,
    - Zusicherung, dass die Sicherheitsleitlinie von der Institutionsleitung durchgesetzt wird, sowie Leitaussagen zur Erfolgskontrolle und
    - Beschreibung der für die Umsetzung des Informationssicherheitsprozesses geplanten (oder bereits etablierten) Organisationsstruktur

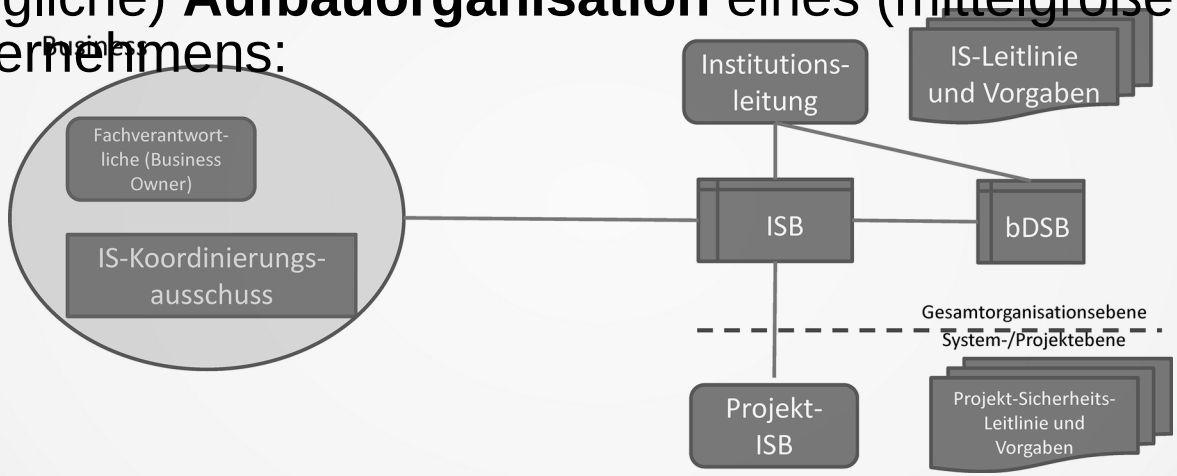
[1)] Ein Informationsverbund umfasst die Gesamtheit von infrastrukturellen, organisatorischen, personellen und technischen Komponenten, die der Aufgabenerfüllung in einem bestimmten Anwendungsbereich der Informationsverarbeitung dienen.

Informationssicherheitsmanagement

- **IS-Prozess – Phase#3 „Organisation des Sicherheitsprozesses“:**
  - **Grundregeln:**
    - Die Gesamtverantwortung für die ordnungsgemäße und sichere Aufgabenerfüllung (und damit für die IS) verbleibt bei der Leitungsebene
    - Es ist mindestens eine Person (typischerweise als ISB) zu benennen, die den IS-Prozess fördert und koordiniert
    - Jeder Mitarbeiter ist gleichermaßen für seine originäre Aufgabe wie für die Aufrechterhaltung der IS an seinem Arbeitsplatz und in seiner Umgebung verantwortlich => IS soll nicht (ausschließlich) *„das Problem anderer Leute“* sein
  - **Integration in organisationsweite Abläufe und Prozesse sowie Projekte**: zB bei Entscheidungen über Outsourcing, die Nutzung neuer elektronischer Vertriebskanäle oder die Anmietung neuer Räumlichkeiten

Informationssicherheitsmanagement

- **IS-Prozess – Phase#3 „Organisation des Sicherheitsprozesses“:**
  - (mögliche) **Aufbauorganisation** eines (mittelgroßen) Unternehmens:



  - Der **ISB** kann (je nach Notwendigkeit durch Projekt-ISBs oder Bereichs-ISBs – bspw IT-Sicherheitsbeauftragter) entlastet werden
  - Der **IS-Koordinierungsausschuss** wird bei Bedarf (zB zur Planung größerer Projekte) einberufen und hat die Aufgabe, das Zusammenspiel zwischen den Fachverantwortlichen, dem ISB und der Unternehmensleitung zu koordinieren
  - Der ISB muss eng mit dem **Datenschutzbeauftragten** zusammenarbeiten oder übt diese Funktion uU in Personalunion aus

Informationssicherheitsmanagement

- **IS-Prozess – Phase#3 „Organisation des Sicherheitsprozesses“:**
  - **Zuständigkeiten und Aufgaben des ISB:**
    - **Steuerung des IS-Prozesses** und Mitwirkung an allen damit zusammenhängenden Aufgaben
    - **Unterstützung der Leitungsebene** bei der Erstellung der Leitlinie zur IS
    - **Erstellung des Sicherheitskonzepts**, des Notfallvorsorgekonzepts und anderer Teilkonzepte
    - Koordination der System-Sicherheitsrichtlinien sowie Etablierung weiterer Richtlinien und Regelungen zur IS
    - **Initiierung und Überprüfung der Realisierung von Sicherheitsmaßnahmen** sowie die Koordination sicherheitsrelevanter Projekte
    - Laufende **Berichterstattung** über den Status quo der IS an die Leitungsebene
    - **Untersuchung von Sicherheitsvorfällen**
    - Initiieren und Koordinieren von **Sensibilisierungs- und Schulungsmaßnahmen** zur IS
    - Hinzuziehen externer Experten (falls sinnvoll/notwendig)
    - Laufende Weiterbildung und Austausch zu aktuellen/neuen Themen, BestPractices, Standards, gesetzlichen Rahmenbedingungen, etc